UniDPP

DIGITAL PRODUCT PASSPORT · MULTI-BODY STEWARDSHIP

UNIDPP CONTRIBUTION

ISO/IEC JTC 5 · DIGITAL PRODUCT PASSPORT

Cross-recognition trust for the Digital Product Passport

2026-11-08

UniDPP — convened under CalConnect, multi-body stewardship

01 · SCOPE

The trust vacancy and the proposal

The EN series assumes a trust layer it does not define: eIDAS is named as the frame, roles carry authorization in EN 18239 and EN 18222 without a trust infrastructure to underwrite them, and nothing in the series tells a Japanese or Chinese verifier how to check a European signature — or vice versa — without adopting the other side's rules. AWI 25534-1 sketches the right answer in one sentence (a global trust anchor registry accrediting regional and national frameworks) and leaves it unimplemented.

This contribution proposes that JTC 5 take **SIGNATIF** — a published, open cross-recognition architecture (signatif.org) — as the basis of workstream D's trust annex, and offers its DPP annex as the starting text. SIGNATIF is not a new PKI; it is the composition of four proven lineages under one verification discipline: the WebPKI with Certificate Transparency (transparency logs), the ePassport CSCA/PKD system (governmental master lists), code-signing practice (key protection and timestamping), and eIDAS (accreditation of trust service providers) — unified by threshold-quorum roots, four-layer scope enforcement, and an algorithm-agility registry.

The requirement it answers is invariant I9 of paper 1 (graded trust) in its sovereignty form: **cross-verification without adopting foreign rules** — a verifier in one jurisdiction checks another jurisdiction's passport projection against anchors in the verifier's own bundle, with scope checked at every link of the chain.

02 · ARCHITECTURE

Trust lists, master list, M-of-K

The trust topology has three tiers:

- **Jurisdictional trust authorities** — threshold groups, not single keys: a jurisdiction's root is held by a quorum (Confium-class threshold operations), so no single key compromise and no single national decision can forge or withdraw trust. Each authority publishes a **trust list** of the issuers, accreditations and algorithm bindings it recognizes.
- **The master list** — a globally multi-witnessed aggregation of jurisdictional trust lists, anchored in an **M-of-K quorum of independent transparency logs**: a master-list entry is trustworthy when at least M of K independent log operators have witnessed it. This answers, mechanically, the question every "single global registry" proposal fails on — *who runs it* — with "nobody alone". Onboarding ceremonies for new jurisdictions and dispute resolution (runner-up to the threshold roots) are specified operations, not diplomacy.
- **Profile-scoped acceptance policies** — each profile declares which authorities, suites and log quorums its verifiers accept, and in which precedence. Trust is thus jurisdiction-scoped by construction; the master list makes foreign anchors *discoverable*, never mandatory.

Transparency logs anchor both trust events and passport events, which yields the availability property paper 1 requires: verification decouples from origin servers — a verifier holding an inclusion proof never needs the issuer's service to be up, and distrust declarations become discoverable for every anchored artifact. The logs anchor **commitments, not facts**: what a log witnesses is a hash, so a log operator can prove inclusion but cannot correlate graph edges — the enumeration-resistance property of invariant I12 (paper 1). The join this section specifies — issuer credentials to profile trust lists, the delegation DAG to roots to the master list — is seam S7 of the twelve enumerated in paper 1.

03 · CRYPTOGRAPHIC SUITES

Multi-suite signatures as the norm

Cryptographic suites are **part of the profile, not the platform**. The same payload carries multiple signatures side by side (the SIGNATIF co-signature model); each verifier checks what its own acceptance policy requires:

Jurisdiction binding	Suite family	Standardization anchor
China profile	SM2 / SM3 / SM4 / SM9, with TLCP transport termination by the regional service provider.	Published as ISO/IEC mechanisms: 14888-3, 10118-3, 18033-3
US federal profile	FIPS 186 / FIPS 197, SHA-2 and SHA-3, in FIPS 140-3 validated modules.	NIST FIPS series
EU profile	eIDAS-acceptable suites.	eIDAS / ETSI
All profiles (migration)	Composite and post-quantum signatures (e.g., ML-DSA) alongside classical, per migration phase.	Algorithm-agility registry (SIGNATIF)

An EU-verifiable ECDSA signature, a China-verifiable SM2 signature and a post-quantum ML-DSA signature over the same commitment coexist on one passport; none is privileged by the platform. Envelope encryption wraps payload keys per recipient under each jurisdiction's permitted key-encapsulation mechanisms, and transport-level overrides live in the profile (a profile whose jurisdiction cannot terminate the TLS profile of EN 18216 terminates its own transport at its regional service provider — L6 of paper 1). The agility registry governs suite lifecycles, so post-quantum migration is a scheduled registry transition, not a flag day.

04 · REVOCATION

The reason determines the retroactivity

Revocation is not one operation: **the reason determines the retroactivity**. This is the single semantic distinction the trust annex must legislate, because every other property follows from it.

- **Prospective reasons** — key compromise *after* a time T, cessation of operations, supersession by a successor key, affiliation change. As-of-T verifications dated before the event remain valid; trusted timestamping protects them, exactly as timestamping protects signed code whose key later rotates.
- **Retroactive reasons** — misissuance, fraudulent issuance, an authority compromised *during a window*. Validity is void **ab initio** (or from the window start); timestamping does *not* protect, exactly as a browser root store distrusting a misissuing CA invalidates that CA's timestamped certificates retroactively.

Distrust declarations therefore carry an explicit `window [start, end]`: artifacts anchored inside the window are voided, artifacts outside it are re-validated, and transparency logs make every anchored artifact's exposure discoverable, so no verifier has to trust the declaring authority's completeness.

The void-ab-initio case, worked

A notified actor fraudulently issues passports for goods that were never manufactured. A superior, quorate body — threshold vote under master-list governance, the SIGNATIF dispute-resolution operation — declares the authority fraudulent, with a window covering the misconduct. The cascade that follows is mechanical, not discretionary: every passport that authority issued inside the window is void from inception, *including those verified months earlier in good faith with valid timestamps*. What protects the good-faith verifiers is not the passports but the **evidentiary reading** of their as-of stamps (section 05); what protects the market is that the fraudulent goods cannot be laundered through time. Distrust cascades follow the window, never exceed it.

Revocation, withdrawal and suspension remain three distinct tracks, as fixed in paper 1's operating model: **cryptographic revocation** (compromise: SIGNATIF revocation propagation to transitively bound artifacts, plus emergency revocation), **legal withdrawal** (accreditation removed: trust-list and profile-binding updates, with grace windows for in-flight verification), and **diplomatic breakdown** (cross-recognition suspended: verification still succeeds under other anchors; affected profiles' acceptance policies quarantine the suspended authority's artifacts rather than the whole system).

05 · VERIFICATION

Three readings, one verdict format

Because law needs all three, a verdict is not one bit. The trust annex defines three readings and requires every verdict to state which it answers:

- **Evidentiary** — what could a diligent verifier have known at T, given the then-current trust state? This reading protects good-faith actors: their as-of stamps are the proof of diligence, and they survive later retroactive distrust of what they verified.
- **Current-state** — is the artifact valid given everything known now? Fraud voids ab initio under this reading, which is what prevents fraudulent goods from being laundered through time and re-entry into circulation.
- **Cryptographic** — do the signature and the chain verify, full stop? Necessary for the other two, sufficient for none of them.

The verdict itself is a **coverage report, not a boolean**: which anchors were reachable, which suites checked, which log quorums witnessed, which window rules applied — the same report shape paper 1 fixes for offline verification and paper 4's conformance tooling consumes. A verifier in one jurisdiction reading another jurisdiction's projection states its reading and its anchor bundle, and the outcome is reproducible by any third party holding the same bundle.

06 · GRAPH TAINT

Fraud propagates as a graph event

Marking a passport fraudulent is a **graph event, not just a trust-list event**. The trust list says something about an authority; the taint says something about goods. It traverses the provenance DAG downstream — the same machinery a recall uses, with a different cause — and it does four things on the way:

- **It taints derived passports** — every passport whose fact-chain depends on the fraudulent issuance inherits the mark, without re-verification of each one from scratch.
- **It recomputes affected claims** — a recycled-content claim built on stolen material collapses when the input passports are tainted, because the claim was always a computed function of its inputs, never an independent assertion.
- **It notifies custodians** — the holders of tainted objects learn of the taint through the same event stream that carries every other lifecycle event of paper 3, and may face suspension of the affected products.
- **It enters the accounts** — mass-balance accounting must carry taint explicitly: a tonne of tainted input is not a tonne of clean input, and the books must be able to say so.

Issuer misconduct escalates beyond taint into a **status-invalidation cascade with adjudication**: statuses are invalidated by due process, the adjudicated outcomes are themselves logged events, and the record of the adjudication is anchorable like any other. The system never confuses "fraudulent" with "merely revoked"; the first is a property of the graph, the second a property of the keys.

07 · SECTOR REALIZATION

CNML under the ESDC open class, with OIML

EN 18246 defines its sector-specific data carrier class (ESDC) as an **open class** — Annex A is explicitly "non-exhaustive" — and the framework treats that openness as an obligation to demonstrate. The first demonstration is **CNML, a post-quantum national metrology PKI, registered as ESDC realization number 4** in the UniDPP portfolio: the fourth enumerated realization of the open class, and the first exercised end-to-end under the trust architecture of this paper.

What CNML demonstrates, concretely: post-quantum credentials operating as profile-bound suites rather than platform-wide flags; notified-actor credentials per EN 18239 carried in the same trust-list structure as ordinary issuer credentials; and a **metrological-validity clause for measured data points** — a measured claim is only as valid as the instrument that produced it, so the profile binds the measurement chain the way other profiles bind the cryptographic chain. The pattern is the replicable vertical template of paper 1: one regulated sector, one profile, one trust binding — repeatable for ErP, battery and metering delegated acts, and adjacent to IDTA 02065/02029 practice without being subordinate to it.

Because trust objects are profile-shaped, the same discipline reaches the registry itself: profile registrations, their version supersessions and their trust bindings (which issuers may attest under them) are **signed, registry-deposited, log-anchored objects**, and the registry is **multi-suite co-signed** so that every jurisdiction verifies profile authenticity under its own crypto policy. Verification path-finds from any render, through the profile and its fact-chain, to an anchor in *the verifier's* bundle, with scope checked at every link; roots are threshold and federated groups — no single key, no single country.

OIML is co-signatory of this paper. The metrology community supplies both the first vertical and the governance vocabulary: profile registration is pattern approval, published calibration is the versioned rule set, uncertainty and decision rules follow GUM/ILAC-G8 practice, and periodic re-verification is a conformance run — the same correspondence paper 1 draws between profiles and legal measuring instruments.

08 · THE ASK

What workstream D should take from this

- **Adopt SIGNATIF's DPP annex as the starting text** of the workstream D trust annex, with signatif.org as the citable source and the annex's registry-to-multi-log quorum as the reference topology.
- **Standardize four things, no more**: the trust-list and master-list formats with M-of-K witnessing; the revocation-reason taxonomy and its retroactivity rules (section 04); the three-reading verdict format with coverage reports (section 05); and taint as a typed graph event in the lifecycle model of paper 3.
- **Keep the trust registry a sibling, not a monolith**: the trust registry (SIGNATIF-shaped, this paper) and the semantic registry (FERIN, paper 2) operate under the same ISO 19135 registration discipline, with no dependency of one on the other's internals.
- **Test, don't assert**: the conformance layer is SIGNATIF ATS plus the ISO 8601 temporal test suite, expressir model validation and carrier tests, executed as part of paper 4's open conformance matrix.

09 · REFERENCES

1. SIGNATIF (signatif.org), including its Digital Product Passport annex; Confium threshold operations.
2. Lineage systems: WebPKI with Certificate Transparency (RFC 6962); ICAO Doc 9303 CSCA/PKD; CA/Browser Forum code-signing and timestamping practice; eIDAS (Regulation (EU) 910/2014) accreditation of trust service providers.
3. Suite anchors: ISO/IEC 14888-3, ISO/IEC 10118-3, ISO/IEC 18033-3 (SM mechanisms); NIST FIPS 186-5, FIPS 197, FIPS 140-3; FIPS 204 (ML-DSA).
4. EN 18239 (notified actors); EN 18246 (ESDC open class, Annex A); EN 18221 (persistence).
5. ISO 19135 (registration discipline); GUM and ILAC-G8 (measurement uncertainty and decision rules).
6. Companion papers 1, 2, 3 and 4 of this series.

UniDPP project, convened under CalConnect — multi-body stewardship; Apache-2.0/MIT per repository.

Paper 5 of 6 · cross-recognition-trust-for-dpp.html · 2026-09-07